AGRUPAMENTO DE ESCOLAS TEMPLÁRIOS

Escola Secundária de Jácome Ratton – Tomar

CURSO PROFISSIONAL

TÉCNICO DE INFORMÁTICA-SISTEMAS

PROVA DE APTIDÃO PROFISSIONAL

Gestor de Palavras-Passe



Pedro Silva

Nº 33882

PROFESSOR(A) ORIENTADOR(A): Ana Rosa

Ano letivo 2021/2022

SELO DE CONFORMIDADE EQAVET

PESSOAS 2030

PORTUGAL 2030

Cofinanciado pela União Europeia

ÍNDICE

I. Introdução 1

II. Projeto 2

1. Desenvolvimento 2

1.1. Metodologia 2

1.2. Resultados/produtos 8

1.4. Análise crítica 15

2. Conclusões 16

3. Webgrafia 16

4. Anexos 18

I. Introdução

No âmbito do Curso Profissional de Técnico de Gestão e Programação de Sistemas Informáticos, este projeto de Prova de Aptidão Profissional (PAP) tem como objetivo o desenvolvimento de uma aplicação para a gestão segura de palavras-passe.

A aplicação pretende dar resposta ao problema atual da utilização de palavras-passe fracas e repetidas em diferentes serviços, bem como à necessidade de proteger credenciais de utilizadores com poucos conhecimentos na área da segurança da informação.

Com o aumento do número de contas online e da quantidade de dados pessoais e profissionais armazenados em formato digital, torna-se essencial disponibilizar ferramentas simples e seguras que auxiliem os utilizadores a guardar as suas credenciais num "cofre" protegido. Assim, este projeto procura conjugar uma interface intuitiva com boas práticas de segurança, garantindo a proteção dos dados armazenados.

II. Projeto

1. Desenvolvimento

1.1. Metodologia

Este projeto foi desenvolvido por etapas. Na primeira etapa, procedi à identificação das necessidades da aplicação, nomeadamente as funcionalidades a implementar e outros requisitos relevantes para o seu correto funcionamento.

Etapa 2 – Aquisição de Conhecimentos

Previamente ao início do desenvolvimento da aplicação, foi necessário proceder à aquisição de conhecimentos fundamentais relativos às tecnologias, ferramentas e conceitos que seriam utilizados ao longo do projeto. Esta etapa revelou-se essencial para garantir uma base sólida de compreensão técnica, permitindo uma implementação mais eficiente das funcionalidades pretendidas.

Base de Dados – MongoDB

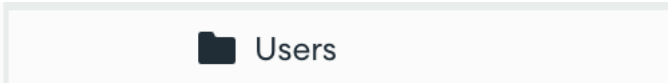
O primeiro domínio de estudo incidiu sobre a tecnologia de base de dados a utilizar. Após uma análise comparativa entre as opções disponíveis, optei pelo MongoDB, uma base de dados não relacional orientada a documentos. Esta escolha fundamentou-se em dois motivos principais.

Em primeiro lugar, o MongoDB destaca-se pela sua versatilidade e flexibilidade no armazenamento de dados. Ao contrário das bases de dados relacionais tradicionais, que exigem uma estrutura rígida e previamente definida, o MongoDB permite uma maior adaptabilidade na organização da informação.

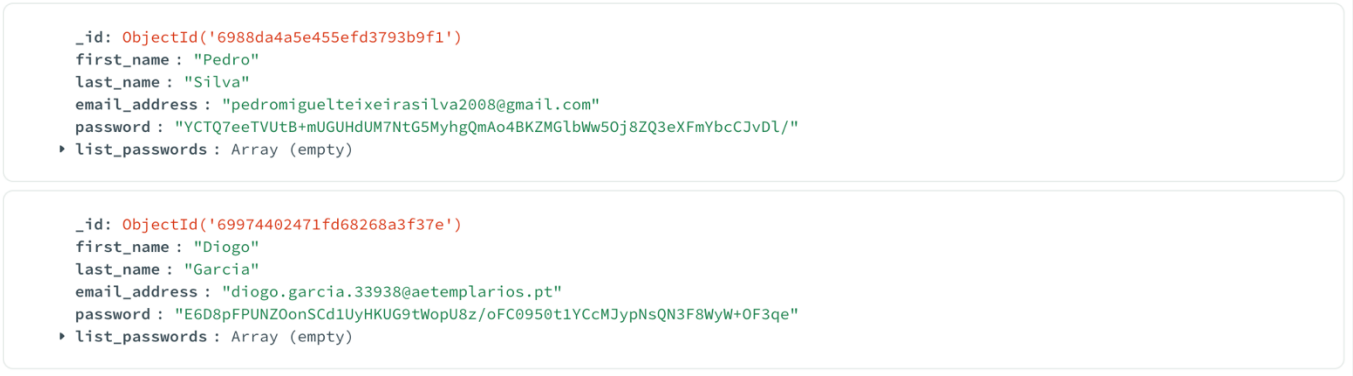
Em segundo lugar, a plataforma MongoDB Atlas possibilita a criação de uma conta gratuita que disponibiliza automaticamente a base de dados na nuvem, funcionando em servidores geridos pela própria MongoDB. Esta característica elimina a necessidade de configuração e manutenção de infraestrutura local, simplificando o processo de desenvolvimento.

No que concerne à estrutura organizacional do MongoDB, este opera através de dois conceitos fundamentais: collections e documents. As collections correspondem, de forma simplificada, às tabelas existentes numa base de dados relacional, enquanto os documents equivalem aos registos dessas tabelas. Contudo, ao contrário do SQL, os documentos são armazenados em formato BSON (Binary JSON), conferindo maior flexibilidade na estrutura dos dados.

Collections



Documents



Linguagem de Programação – C# e XAML

A fase subsequente consistiu na aquisição de conhecimentos relativos à linguagem C#, uma vez que nunca havia utilizado esta linguagem anteriormente. Paralelamente, procedi à aprendizagem do XAML (eXtensible Application Markup Language), utilizado para a construção da interface gráfica.

Criptografia e Segurança

Neste âmbito, foi fundamental compreender a distinção entre encriptação e funções de hash. A encriptação consiste num processo reversível, no qual a informação original pode ser recuperada através de uma chave de desencriptação. Por outro lado, as funções de hash constituem processos unidirecionais, onde a informação original não pode ser recuperada, sendo utilizadas para armazenamento seguro de palavras-passe.

A aquisição destes conhecimentos proporcionou uma base teórica sólida, indispensável para as fases subsequentes do desenvolvimento.

Etapa 3 – Desenvolvimento da Aplicação

A terceira e última etapa do projeto correspondeu à fase de desenvolvimento da aplicação. Esta fase integrou várias subetapas, incluindo a implementação das funcionalidades definidas, a aplicação de mecanismos de segurança e a realização de testes com o objetivo de garantir o correto funcionamento da aplicação.

Segurança da Palavra-passe Mestra

Num gestor de palavras-passe, a segurança da palavra-passe mestra constitui um elemento absolutamente fundamental, uma vez que esta representa a única barreira de proteção entre um potencial atacante e todas as credenciais armazenadas pelo utilizador. Para garantir a máxima segurança deste componente crítico, optei pela utilização da função de hash Argon2, vencedora do Password Hashing Competition em 2015, uma competição internacional que teve como objetivo selecionar o algoritmo mais seguro e robusto para o armazenamento de palavras-passe.

O funcionamento desta função baseia-se na transformação da palavra-passe original através de um cálculo matemático complexo, resultando numa sequência de caracteres completamente irreconhecível e impossível de reverter para obter a palavra-passe original.

Para a geração do hash da palavra-passe mestra, foi necessário definir um conjunto de configurações essenciais que determinam o nível de segurança do processo:

Em primeiro lugar, implementei a utilização de um salt aleatório. O salt consiste numa combinação de caracteres gerada aleatoriamente que é adicionada à palavra-passe do utilizador antes do cálculo do hash. Esta técnica tem como principal objetivo prevenir os denominados ataques de tabela, também conhecidos como rainbow table attacks. Estes ataques consistem na utilização de tabelas pré-calculadas que contêm milhões de combinações de palavras-passe comuns e os respetivos valores de hash. Sem a utilização de um salt, um atacante poderia simplesmente comparar o hash armazenado na base de dados com as entradas da sua tabela pré-calculada, identificando rapidamente a palavra-passe correspondente. Contudo, com a adição de um salt único para cada utilizador, mesmo que dois utilizadores possuam a mesma palavra-passe, os valores de hash resultantes serão completamente diferentes, tornando as tabelas pré-calculadas totalmente ineficazes.

Em segundo lugar, defini o número de iterações do algoritmo. Este parâmetro determina quantas vezes o cálculo do hash é executado de forma encadeada, ou seja, calcula-se o hash da palavra-passe original, posteriormente calcula-se o hash desse resultado, e assim sucessivamente até atingir o limite definido. Implementei um número de iterações consideravelmente elevado, o que aumenta significativamente o tempo necessário para calcular cada hash e, consequentemente, dificulta tentativas de ataques por força bruta.

Em terceiro lugar, configurei a quantidade de memória RAM utilizada durante o processo de cálculo do hash. Esta configuração reveste-se de particular importância na proteção contra atacantes que utilizam hardware especializado. Defini um valor elevado de memória necessária para o cálculo, o que constitui uma medida de segurança extremamente eficaz. A razão para tal prende-se com o facto de que atacantes frequentemente recorrem a placas gráficas (GPUs) ou hardware especializado (ASICs) para realizar ataques de força bruta, uma vez que estes dispositivos conseguem executar milhões de cálculos por segundo. Contudo, este tipo de hardware possui tipicamente quantidades limitadas de memória dedicada. Ao exigir uma quantidade elevada de memória para cada cálculo de hash, torna-se economicamente inviável e tecnicamente impraticável realizar ataques em larga escala com este tipo de equipamento, uma vez que cada tentativa de cálculo requer a alocação de uma quantidade substancial de memória.

Por fim, defini que o processo de cálculo deve utilizar oito núcleos do processador em paralelo. Esta configuração, denominada paralelismo, permite distribuir a carga computacional por múltiplos núcleos, otimizando o desempenho do algoritmo em sistemas legítimos enquanto adiciona uma camada adicional de complexidade para potenciais atacantes.

```
var argon2 = new Argon2id(Encoding.UTF8.GetBytes(password)) //converte a password de texto para bytes
{
    Salt = salt,
    DegreeOfParallelism = 8, // número de threads a serem usadas
    Iterations = 8, // número de iterações
    MemorySize = 131072 // memória usada em KB (128 MB)
};
```

Após a aplicação de todas estas configurações, o hash resultante é armazenado de forma segura na base de dados. Importa salientar que estas mesmas definições são posteriormente utilizadas durante o processo de autenticação: quando o utilizador introduz a sua palavra-passe no ecrã de login, a aplicação calcula o hash da palavra-passe inserida utilizando os mesmos parâmetros, efetua a leitura do hash armazenado na base de dados e compara

ambos os valores para verificar se a palavra-passe introduzida corresponde à palavra-passe correta.

Verificação por Correio Eletrónico

Com o objetivo de proporcionar uma camada adicional de segurança para a conta do utilizador, que irá conter dados sensíveis correspondentes a múltiplas palavras-passe, implementei um sistema de verificação por correio eletrónico utilizando a API do Gmail. Este mecanismo funciona de forma semelhante a uma autenticação de dois fatores, sendo ativado tanto no processo de criação de conta como no processo de login.

O funcionamento deste sistema consiste no envio automático de uma mensagem de correio eletrónico para o endereço associado à conta do utilizador, contendo um código de verificação aleatório composto por oito dígitos. Este código possui uma validade temporal limitada a cinco minutos, após os quais expira e torna-se inválido, garantindo assim que códigos antigos não possam ser reutilizados. O utilizador deve então introduzir o código recebido na aplicação, onde é efetuada a verificação da sua correspondência e validade.

Para que o envio de mensagens de correio eletrónico seja executado com sucesso, a aplicação necessita de obter autorização por parte dos serviços da Google. Este processo de autorização é realizado através do protocolo OAuth 2.0, no qual a aplicação recebe tokens de acesso. Estes tokens funcionam de forma análoga a um cartão de autorização digital, certificando que foi concedida permissão à aplicação para executar determinadas ações em nome do utilizador. No contexto deste projeto, os tokens autorizam a aplicação a utilizar uma conta de correio eletrónico específica, criada exclusivamente para este propósito, para o envio das mensagens contendo os códigos de verificação.

```
using (var stream = new FileStream(credentialsPath, FileMode.Open, FileAccess.Read)) //
{
    string tokenPath = Path.Combine(AppDomain.CurrentDomain.BaseDirectory, "token"); //
    credential = await GoogleWebAuthorizationBroker.AuthorizeAsync(
        GoogleClientSecrets.FromStream(stream).Secrets, // Converte o credentials.json
        Scopes, // Permissões que a app está a pedir (neste caso, só enviar emails)
        "user", //
        CancellationToken.None, // Não permito cancelamento da autorização
        new FileDataStore(tokenPath, true) // Guarda o token de acesso na pasta "token"
    );
}
```

1.2. Resultados/produtos

O resultado final deste projeto consiste numa aplicação de ambiente de trabalho denominada **Password Security**, desenvolvida com recurso à framework WinUI 3 e à linguagem C#. A aplicação encontra-se plenamente funcional e cumpre todos os objetivos inicialmente definidos, proporcionando ao utilizador uma ferramenta segura e intuitiva para a gestão das suas palavras-passe. De seguida, apresentam-se as diversas páginas e funcionalidades que compõem a aplicação.

Página de Criação de Conta

A primeira interação do utilizador com a aplicação ocorre na página de criação de conta. Nesta página, o utilizador deve preencher os seus dados pessoais, nomeadamente o primeiro nome, apelido, endereço de correio eletrónico e palavra-passe mestra. É igualmente solicitada a confirmação da palavra-passe e o preenchimento de perguntas de segurança, que poderão ser utilizadas numa eventual recuperação de conta. A página inclui ainda um seletor de idioma, permitindo ao utilizador escolher entre Português, Inglês, Espanhol e Francês.

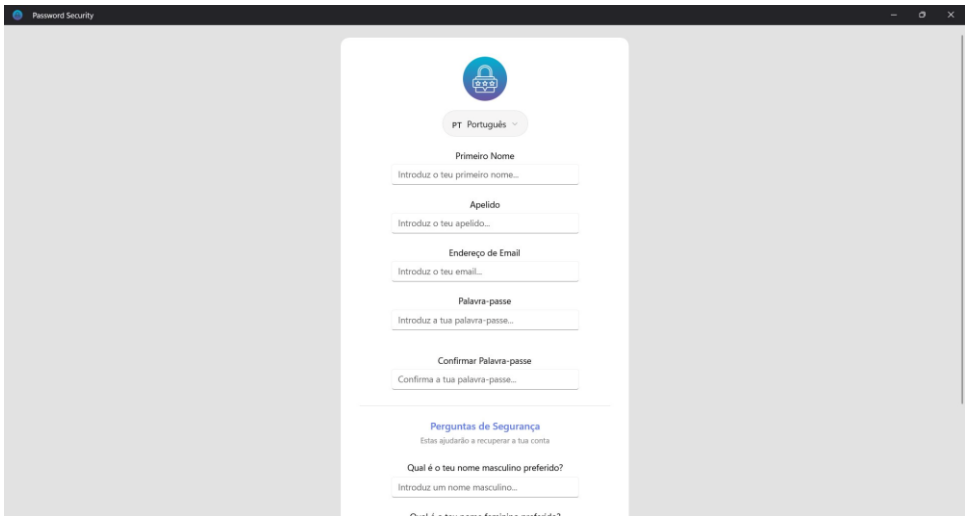


Figura 1 – Página de criação de conta

Página de Login

Após a criação da conta, o utilizador acede à página de login, onde deve introduzir o seu endereço de correio eletrónico e a palavra-passe mestra. Esta página disponibiliza igualmente a opção "Esqueceste a tua palavra-passe?", que permite ao utilizador recuperar o acesso à sua conta através das perguntas de segurança definidas durante o registo. Na parte inferior, encontra-se uma hiperligação para a página de criação de conta, destinada a novos utilizadores.

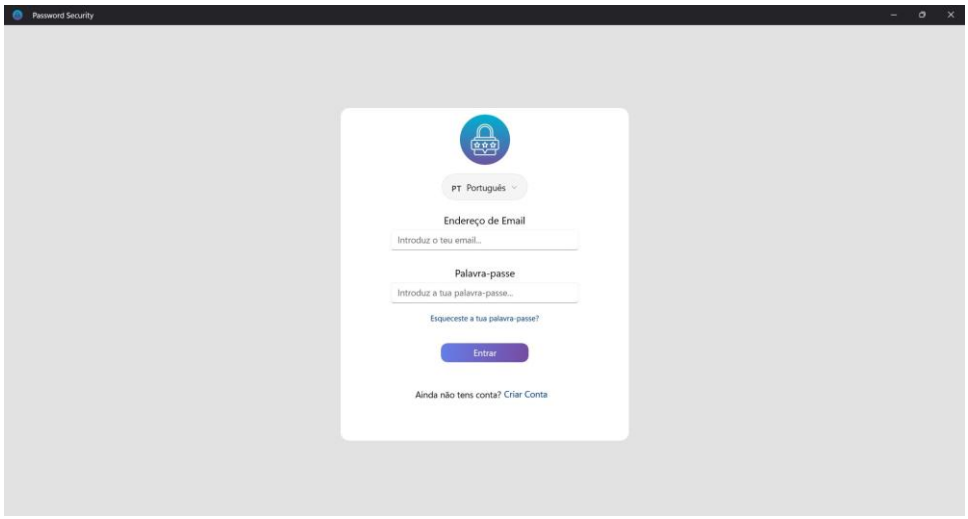


Figura 2 – Página de login

Verificação por Correio Eletrónico

Após a introdução correta das credenciais na página de login, a aplicação envia automaticamente um código de verificação de oito dígitos para o endereço de correio eletrónico do utilizador. Este mecanismo funciona como uma autenticação de dois fatores, garantindo que apenas o proprietário legítimo da conta consegue aceder à aplicação. O código possui uma validade temporal limitada a cinco minutos.

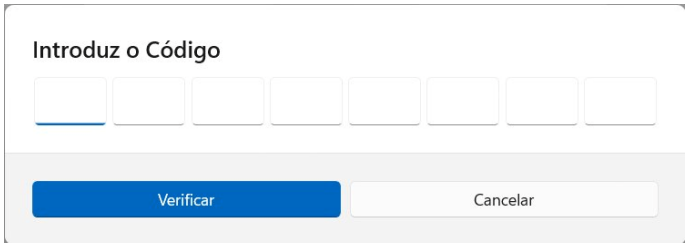


Figura 3 – Diálogo de verificação por correio eletrónico

Página Inicial (Dashboard)

Após a autenticação bem-sucedida, o utilizador é direcionado para a página inicial da aplicação. Esta página apresenta uma mensagem de boas-vindas personalizada com o nome do utilizador e um resumo estatístico do cofre de palavras-passe, incluindo o número total de credenciais armazenadas e a sua distribuição por categorias (Social, Work, Bank e Other). A página inclui ainda uma secção de alertas de segurança que identifica palavras-passe fracas e duplicadas, auxiliando o utilizador na manutenção de boas práticas de segurança. O menu lateral permite a navegação entre as diferentes secções da aplicação.

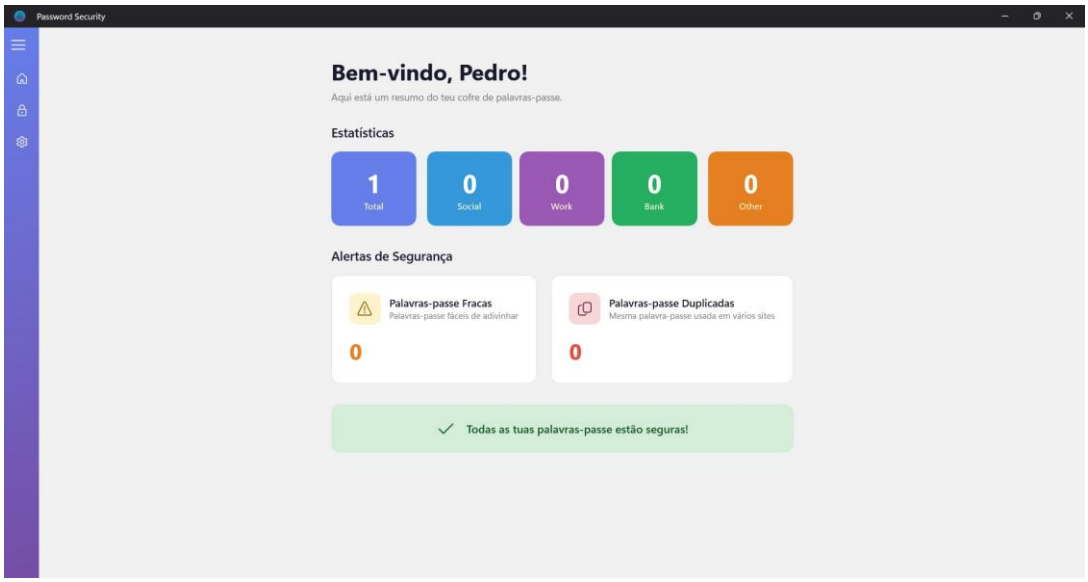


Figura 4 – Página inicial com estatísticas e alertas de segurança

Adicionar Palavra-passe

A funcionalidade de adição de palavras-passe é apresentada através de um formulário intuitivo onde o utilizador pode introduzir o nome do site, o URL, o endereço de correio eletrónico ou nome de utilizador, a palavra-passe, a categoria e notas opcionais. O formulário integra um indicador visual de força da palavra-passe, que avalia em tempo real a robustez da palavra-passe introduzida. Adicionalmente, disponibiliza um gerador automático de palavras-passe fortes, acessível através de um ícone dedicado, que cria palavras-passe aleatórias e seguras. Todas as palavras-passe são encriptadas com AES-256-GCM antes de serem armazenadas na base de dados.

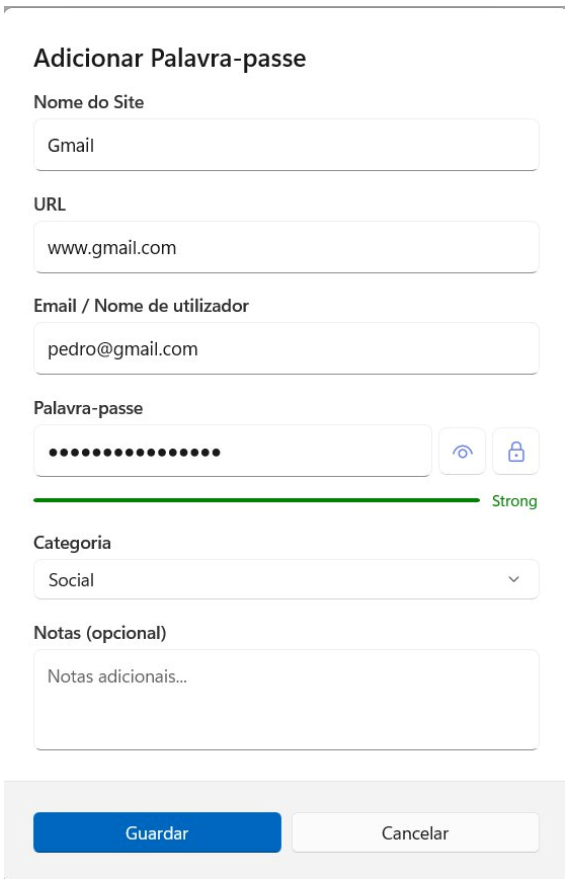


Figura 5 – Formulário de adição de palavra-passe com indicador de força

Página de Palavras-passe

A página de palavras-passe constitui o núcleo funcional da aplicação. Nesta página, o utilizador pode visualizar todas as credenciais armazenadas no seu cofre, apresentadas sob a forma de cartões individuais que exibem o nome do site, o endereço de correio eletrónico associado e a palavra-passe ocultada. A página dispõe de uma barra de pesquisa para localização rápida de credenciais e de um filtro por categoria. Para cada entrada, estão disponíveis quatro ações: visualizar a palavra-passe, copiar para a área de transferência, editar os dados e eliminar a entrada. O botão "Adicionar" no canto superior direito permite a criação de novas entradas.

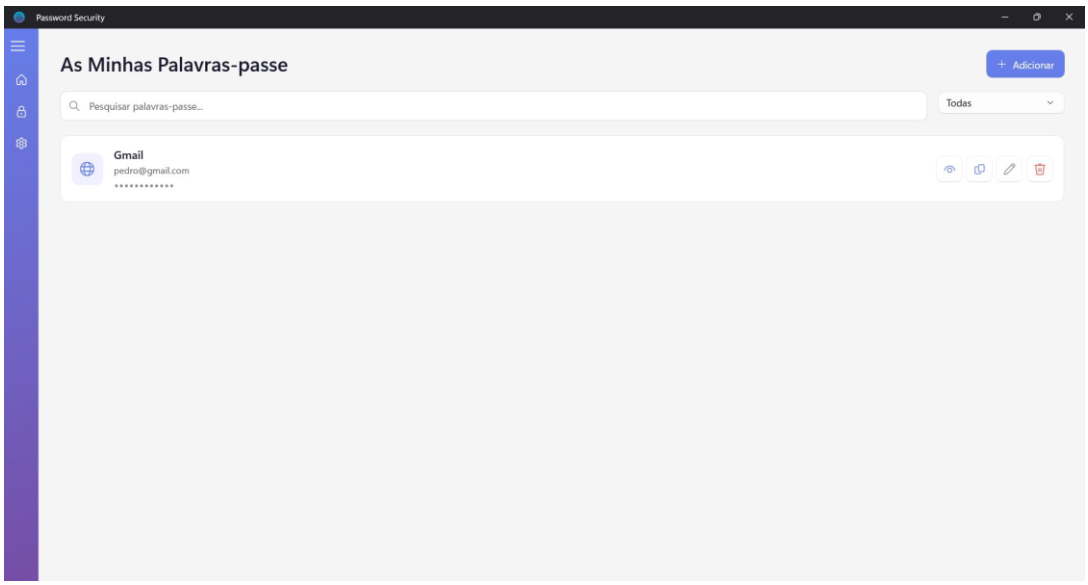


Figura 6 – Página de gestão de palavras-passe

Página de Definições

A página de definições permite ao utilizador gerir as preferências da sua conta. Na secção de informação da conta, são apresentados o nome, apelido e endereço de correio eletrónico do utilizador. A secção de idioma permite alterar o idioma da aplicação entre Português, Inglês, Espanhol e Francês, sendo a alteração aplicada após o reinício da aplicação. A secção de segurança inclui uma opção para exigir verificação adicional (palavra-passe mestra e código de autenticação) para ações sensíveis como visualizar, copiar, editar ou apagar palavras-passe. Estão igualmente disponíveis os botões para alterar a palavra-passe mestra e as perguntas de segurança. Por fim, a página disponibiliza as opções de terminar sessão e de apagar a conta permanentemente.

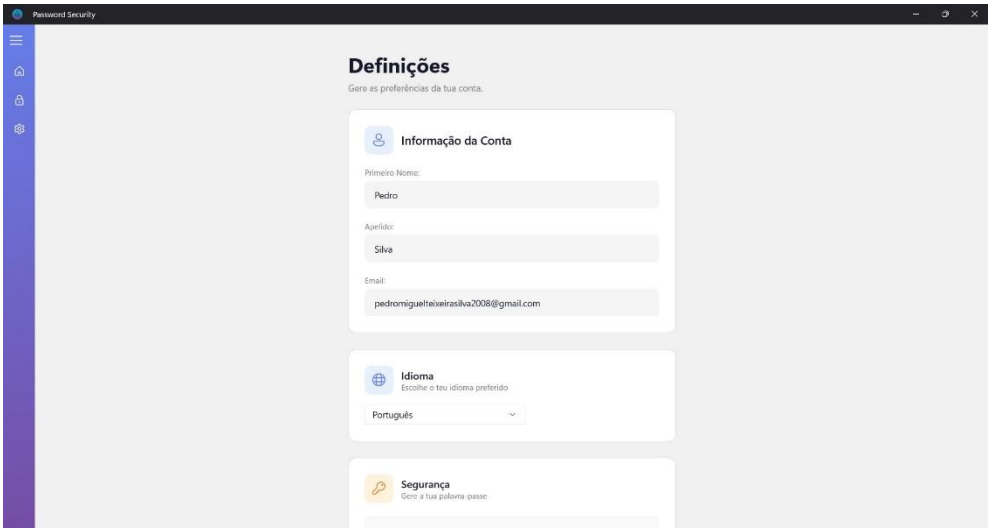


Figura 7 – Página de definições (informação da conta, idioma e segurança)



Figura 8 – Página de definições (ações sensíveis, gestão de conta)

Verificação de Identidade

Para a realização de ações sensíveis, como a alteração de definições de segurança ou a gestão de palavras-passe (quando a opção de verificação se encontra ativada), a aplicação solicita ao utilizador a introdução da sua palavra-passe mestra e do código de autenticação gerado pela aplicação Google Authenticator. Este mecanismo de dupla verificação garante que apenas o proprietário legítimo da conta pode executar operações críticas, mesmo que a sessão já se encontre iniciada.

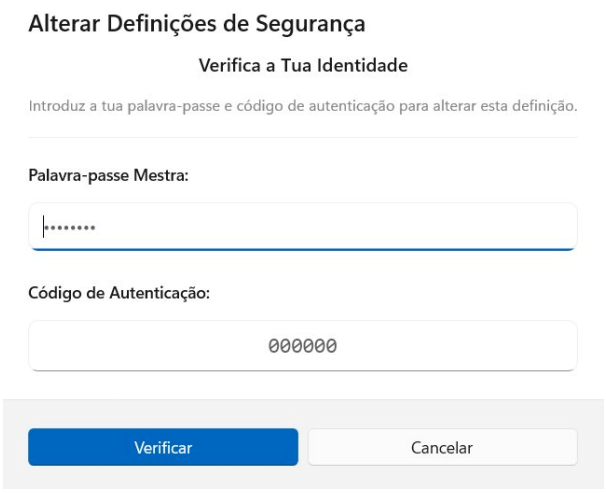


Figura 9 – Diálogo de verificação de identidade

Funcionalidades Adicionais

Para além das funcionalidades acima apresentadas, a aplicação integra ainda as seguintes funcionalidades complementares:

Alteração da Palavra-passe Mestra – O utilizador pode alterar a sua palavra-passe mestra através da página de definições. Este processo requer a verificação da identidade do utilizador através da palavra-passe atual e do código de autenticação, seguida da definição de uma nova palavra-passe com confirmação. Após a alteração, todas as palavras-passe armazenadas são reencriptadas com a nova chave derivada.

Alteração das Perguntas de Segurança – O utilizador pode atualizar as suas perguntas de segurança, utilizadas no processo de recuperação de conta. Esta ação requer igualmente a verificação prévia da identidade.

Recuperação de Palavra-passe – Caso o utilizador esqueça a sua palavra-passe mestra, a aplicação disponibiliza um mecanismo de recuperação baseado nas perguntas de segurança definidas durante o registo. Após a resposta correta às perguntas, o utilizador pode definir uma nova palavra-passe mestra.

Configuração do Google Authenticator (TOTP) – No primeiro login após a criação da conta, o utilizador é direcionado para uma página de configuração da autenticação de dois fatores, onde é apresentado um código QR que deve ser lido pela aplicação Google Authenticator. Esta configuração é obrigatória e garante uma camada adicional de segurança para todas as operações sensíveis realizadas na aplicação.

Suporte Multilingue – A aplicação suporta quatro idiomas: Português, Inglês, Espanhol e Francês. Todas as strings da interface foram implementadas através de ficheiros de recursos (.resw), permitindo a alternância dinâmica entre idiomas.

1.3. Análise crítica

No decorrer do desenvolvimento deste projeto, surgiram diversas dificuldades que exigiram dedicação e capacidade de adaptação para serem ultrapassadas. A primeira e mais significativa prendeu-se com o facto de nunca ter utilizado a linguagem C# nem a linguagem de marcação XAML anteriormente, o que implicou um processo de aprendizagem desde o início. Esta dificuldade foi superada através de um estudo autónomo e progressivo, no qual fui adquirindo os conhecimentos necessários à medida que as funcionalidades eram implementadas, consolidando gradualmente a compreensão da linguagem e dos seus paradigmas, nomeadamente conceitos de programação orientada a objetos como herança, encapsulamento e polimorfismo.

Outra dificuldade relevante consistiu na compreensão dos conceitos de criptografia essenciais para o projeto. A distinção entre funções de hash e encriptação reversível, o funcionamento do salt e a sua importância na prevenção de ataques de tabela, bem como o processo de derivação de chaves através do PBKDF2, constituíram temas que exigiram um estudo teórico aprofundado antes de proceder à sua implementação prática. De forma semelhante, a configuração da API do Gmail com o protocolo de autorização OAuth 2.0 revelou-se um processo complexo, uma vez que envolvia a criação de credenciais na plataforma Google Cloud, a gestão de tokens de acesso e a correta integração do fluxo de autorização na aplicação. Estas dificuldades foram superadas através de uma análise cuidadosa da documentação oficial das respetivas tecnologias e de uma abordagem iterativa de tentativa e correção, que permitiu compreender o funcionamento interno de cada componente e implementá-los de forma correta e segura.

2. Conclusões

O presente projeto permitiu concretizar com sucesso o objetivo inicialmente definido: o desenvolvimento de uma aplicação funcional, segura e intuitiva para a gestão de palavras-passe. A aplicação Password Security integra mecanismos de segurança robustos, nomeadamente o hashing da palavra-passe mestra com Argon2, a encriptação das credenciais armazenadas com AES-256-GCM, a verificação por correio eletrónico através da API do Gmail e a autenticação de dois fatores com Google Authenticator (TOTP). Paralelamente, a interface gráfica foi concebida de forma a proporcionar uma experiência de utilização simples e acessível, complementada pelo suporte a quatro idiomas, o que confere à aplicação uma maior abrangência e versatilidade.

Para além do produto final desenvolvido, este projeto revelou-se uma experiência de aprendizagem extremamente enriquecedora a nível pessoal e profissional. O contacto com tecnologias e conceitos até então desconhecidos, como a linguagem C#, a framework WinUI 3, a base de dados MongoDB Atlas e os fundamentos de criptografia aplicada, contribuiu significativamente para o alargamento das minhas competências técnicas. O processo de desenvolvimento exigiu igualmente o aperfeiçoamento de competências transversais, como a capacidade de resolução de problemas, a gestão de tempo e a autonomia na aquisição de novos conhecimentos. Considero, assim, que os objetivos propostos foram integralmente cumpridos e que o projeto constitui uma base sólida para eventuais melhorias futuras, como a introdução de funcionalidades adicionais ou a adaptação da aplicação para outras plataformas.

3. Webgrafia

Google. *Gmail API – Overview*. Google Developers - https://developers.google.com/gmail/api

Google. *OAuth 2.0 para aplicações de ambiente de trabalho*. Google Identity - https://developers.google.com/identity/protocols/oauth2

Microsoft. *Documentação da linguagem C#*. Microsoft Learn - https://learn.microsoft.com/pt-pt/dotnet/csharp/

Microsoft. *Documentação do Windows App SDK e WinUI 3*. Microsoft Learn - https://learn.microsoft.com/pt-pt/windows/apps/winui/winui3/

Microsoft. *Classe AesGcm – System.Security.Cryptography*. Microsoft Learn - https://learn.microsoft.com/en-us/dotnet/api/system.security.cryptography.aesgcm

Microsoft. *Classe Rfc2898DeriveBytes – System.Security.Cryptography*. Microsoft Learn - https://learn.microsoft.com/en-us/dotnet/api/system.security.cryptography.rfc2898derivebytes

MongoDB. *Documentação do MongoDB*. MongoDB, Inc - https://www.mongodb.com/docs/

MongoDB. *MongoDB Atlas – Cloud Database Service*. MongoDB, Inc - https://www.mongodb.com/atlas

Khovratovich. *Argon2* - https://www.password-hashing.net/

NuGet. *Konscious.Security.Cryptography.Argon2*. NuGet Gallery - https://www.nuget.org/packages/Konscious.Security.Cryptography.Argon2

NuGet. *Otp.NET*. NuGet Gallery - https://www.nuget.org/packages/Otp.NET

4. Anexos

Icone Aplicação



Aplicação de inspiração (Palavras-Passe IOS)



